Rapport d’analyse statique - UnCrackable-Level1

Informations générales

- **Date d'analyse :** 25/04/2026
- **Analyste :** Sara Jamiri
- **APK analysé :** UnCrackable-Level1.apk
- **Version :** 1.0
- **Provenance :** APK fourni par l’enseignant (OWASP MSTG Lab)
- **Outils utilisés :** JADX GUI v1.5.5, dex2jar v2.4, JD-GUI v1.x

Résumé exécutif

Cette analyse statique a révélé **3 vulnérabilités potentielles** dans l'application *UnCrackable-Level1*.

Les principales préoccupations concernent :

- l’exposition implicite d’un composant (MainActivity),
- la présence d’indicateurs de mode debug dans le code,
- l’absence de mécanismes de protection visibles contre l’analyse.

Le niveau de risque global est évalué comme **Moyen**.

Actions prioritaires recommandées :

1. Désactiver toute logique liée au mode debug en production
2. Restreindre l’accès aux composants exportés
3. Renforcer l’obfuscation et la protection du code

Constats détaillés

Constat 1 : Activité exportée implicitement

Sévérité : Moyenne
Description : L’activité principale contient un intent-filter, ce qui la rend accessible depuis d’autres applications sans restriction explicite.
Localisation : AndroidManifest.xml → MainActivity
Impact potentiel : Une application malveillante pourrait interagir avec cette activité et déclencher des comportements non prévus.
Remédiation recommandée : Définir explicitement android:exported="false" si l’exposition n’est pas nécessaire.

Constat 2 : Présence d’indicateur de mode debug

Sévérité : Moyenne
Description : Une chaîne "App is debuggable!" est présente dans le code, indiquant une logique liée au mode debug.
Localisation : MainActivity (code source)
Impact potentiel : Le mode debug peut exposer des informations internes et faciliter l'analyse ou l'exploitation.
Remédiation recommandée : Désactiver le mode debug en production et supprimer les messages sensibles.

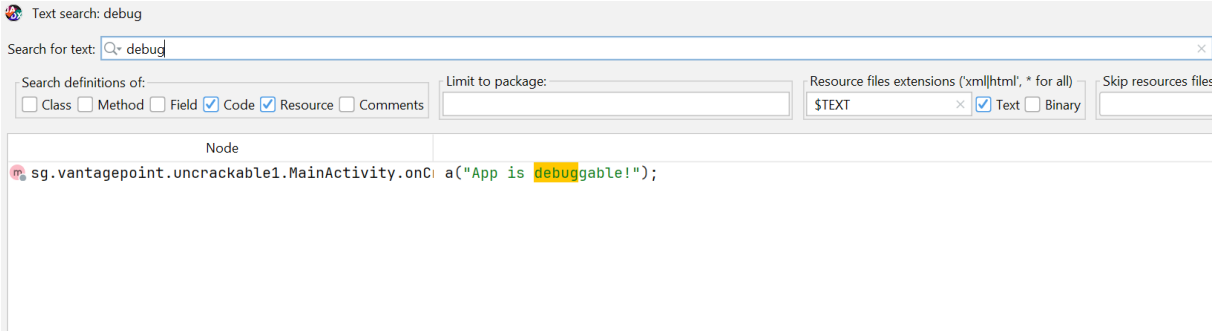

Figure 2 : Détection du mode debug dans le code (JADX)

Constat 3 : Code obfusqué mais analyse possible

Sévérité : Faible
Description : Certaines classes utilisent des noms obfusqués (ex : c.a(), c.b()), mais restent compréhensibles via décompilation.
Localisation : Code source (JADX / JD-GUI)
Impact potentiel : Un attaquant peut toujours analyser et comprendre la logique de l'application.
Remédiation recommandée : Renforcer l'obfuscation avec des outils comme ProGuard ou R8.

Annexes

Permissions demandées

- Aucune permission déclarée

Composants exportés

- MainActivity (exportée implicitement via intent-filter)

Autres éléments pertinents

- Aucune URL externe détectée
- Aucune API ou clé sensible trouvée
- Aucune configuration debuggable ou cleartextTraffic dans le manifest

Comme illustré ci-dessus, l'activité principale contient un intent-filter, ce qui la rend exportée implicitement.

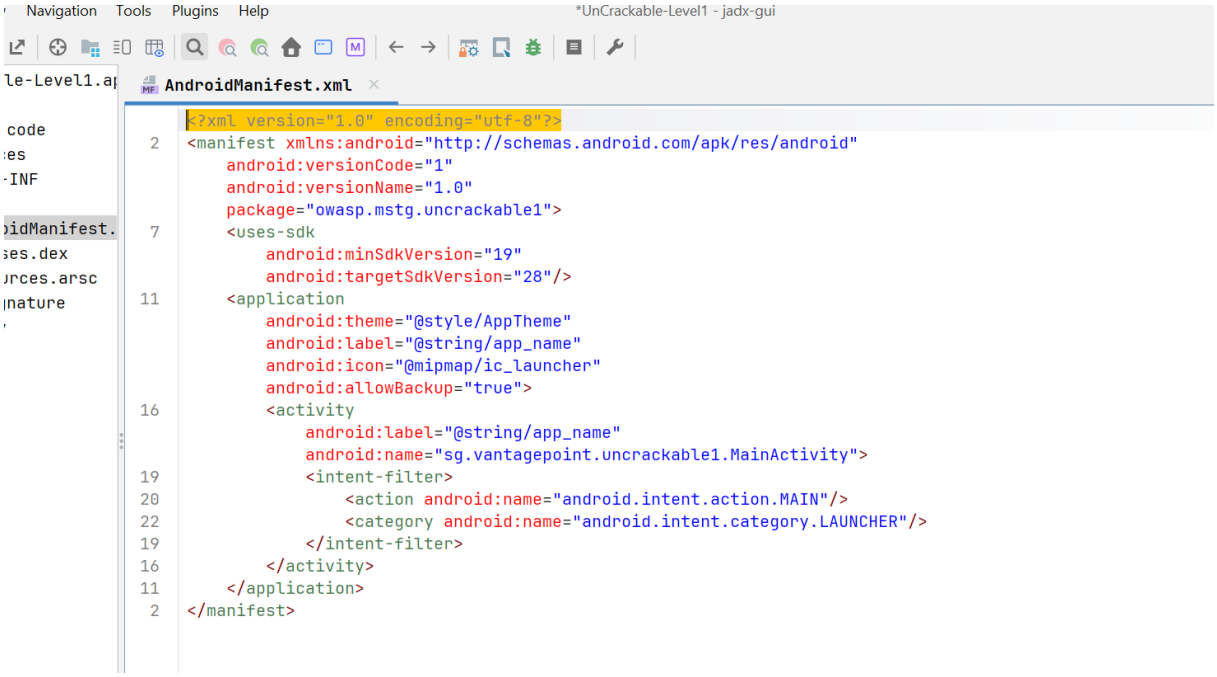

Figure 3 : Analyse du fichier AndroidManifest.xml (JADX)